GUÍA DE INTEGRACIÓN

AntiEstafa AR

Los empleados reportan estafas y phishing; TERO abre la alerta, el caso y suma cobertura MITRE T1566.

Versión	Aplicación	Repositorio
1.0 · Octubre 2026	antiestafa-ar-2.vercel.app	github.com/Ridioortv/analicistec

Qué se suma: TERO Security cuida los equipos, servidores y la red de la empresa. AntiEstafa cubre lo que le llega **a las personas**: el WhatsApp falso del "gerente", el audio del "banco", el link de un proveedor trucho, el QR cambiado. Juntos, la empresa queda protegida de punta a punta, y TERO suma detección de **Phishing (MITRE ATT&CK T1566)**, que en su propio dashboard de demostración aparece como brecha de detección.

> Un servicio de **tecnoros.ar** · Hecho por Manuel A. y María Sofía Genta.

1. Cómo funciona

```
Empleado de la empresa cliente
   │  revisa un mensaje, audio, link o QR en AntiEstafa (con la marca de la empresa)
   ▼
AntiEstafa AR ──► resultado al empleado (semáforo, qué hacer, 911, denuncia)
   │  si da ESTAFA o SOSPECHOSO
   ▼
siem-service de TERO  ──►  regla Sigma "AntiEstafa"  ──►  alerta
                                                          │
                                        SOAR: notificar + abrir caso (+ bloquear
dominio, en simulación)
                                                          │
                                        Casos · Reportes · Purple Team (T1566 cubierta)
```

- El empleado ve en su resultado: **"Le avisamos al equipo de seguridad de tu empresa"**.
- El aviso sale **después** de responderle al empleado: si TERO no responde, el empleado no espera ni ve errores.
- Funciona también con el **bot de WhatsApp** (`/api/v1/analizar`) y con la revisión de **links y QR**.

2. Qué datos se mandan (privacidad)

Por defecto **no** se manda el texto del mensaje ni lo que dice el audio. Se manda:

Campo	Ejemplo
Veredicto y riesgo	`estafa`, `92`
Canal	`mensaje`, `captura`, `audio`, `link`, `qr` o `bot`
Señales detectadas	"Imita a Mercado Pago", "Te pide el código de verificación"
Dominios de los links (indicadores)	`mercadopag0-seguridad.example`
Técnicas MITRE	T1566, T1566.002 (link), T1566.004 (voz), T1598 (pide datos)
Huella	hash corto del texto, para agrupar reportes del mismo mensaje sin guardarlo
Organización	el id de la empresa en TERO

Si la empresa lo pide expresamente, con `TERO_INCLUIR_TEXTO=true` se manda también el texto o la transcripción. La página **Privacidad y términos** se lo explica al empleado automáticamente.

Formato: JSON tipo **ECS** (el que usan OpenSearch y las reglas Sigma). Ejemplo completo en `integraciones/tero/evento-ejemplo.json`.

3. Configurar AntiEstafa para una empresa de TERO

En el proyecto de Vercel de esa empresa (uno por empresa, como en la guía de tecnoros):

Variable	Valor
`NEXT_PUBLIC_MARCA_NOMBRE`	Nombre de la empresa cliente (aparece "Empresa · un servicio de tecnoros.ar")
`NEXT_PUBLIC_MARCA_LOGO`	Logo de la empresa (https)
`NEXT_PUBLIC_MARCA_CONTACTO`	WhatsApp de la mesa de ayuda o del equipo de seguridad
`TERO_SIEM_URL`	URL **https** donde el siem-service de TERO recibe eventos (ver punto 4)
`TERO_API_KEY`	Token que genera TERO para esta integración
`TERO_ORGANIZACION`	Id de la organización en TERO
`TERO_INCLUIR_TEXTO`	`false` (recomendado) o `true`

Para probar la conexión sin esperar un caso real:

```
npm run tero:prueba
```

Manda un evento de prueba (marcado `[PRUEBA]`) y dice si TERO lo aceptó.

4. Qué hay que hacer del lado de TERO

TERO corre en la red del cliente con los puertos solo en `127.0.0.1`, así que:

1. **Recibir eventos:** el `siem-service` (puerto 8005) necesita un endpoint de ingesta que acepte `POST` con JSON y `Authorization: Bearer <token>`. Si ya existe uno para logs, se usa ese; si no, hay que agregar uno chico que guarde el evento como log en OpenSearch con la organización indicada.
2. **Publicarlo con HTTPS:** como recomienda el manual de TERO, detrás del proxy HTTPS de la instalación (por ejemplo `https://tero.empresa.com.ar/api/siem/ingest`), solo para esa ruta y con el token.
3. **Cargar las reglas Sigma** de `integraciones/tero/sigma/` en SIEM → reglas:
   - `antiestafa-estafa-detectada.yml` → nivel **high**
   - `antiestafa-sospechoso.yml` → nivel **medium**
   - `antiestafa-voz-clonada.yml` → nivel **critical** (audios: posible voz clonada, típico fraude del "CEO") Todas llevan etiquetas `attack.t1566…`, así el Purple Team las cuenta en la cobertura.
4. **Playbook SOAR sugerido** "Phishing reportado por empleado" (arranca en modo simulación, como todo en TERO):
   1. Notificar al canal de seguridad (email o Slack) con el resumen y los dominios.
   2. Abrir un **caso** con prioridad según el nivel de la regla y SLA de 4 h (crítico) / 24 h (alto).
   3. (Opcional) Bloquear los dominios en el firewall con el conector de integraciones.
   4. Si el mismo dominio o la misma huella llega de 3 o más empleados en 24 h: avisar a toda la empresa ("está circulando esta estafa").
5. **Dashboard:** sumar una tarjeta "Estafas reportadas por empleados (7 días)" y el top de dominios.

Esto no se puede hacer desde este repositorio porque es código de TERO: con el repo de TERO se arma en una tarde.

5. Ideas para seguir

Idea	Para qué
Campañas de concientización con el modo Practicá, con resultados por área en TERO	Medir quién cae y capacitar
Bloqueo automático de dominios reportados en el firewall de todas las sedes	Que un empleado avisado proteja a todos
Alertas a toda la empresa cuando una estafa se repite	Cortar campañas internas rápido
Verificar proveedores: CBU/alias y comprobantes de pago de proveedores contra la lista de TERO	Fraude del "cambio de cuenta del proveedor"
Voz del CEO: regla y guía específica para pedidos de transferencias urgentes por audio	Fraude BEC por voz clonada
Reporte mensual "Fraude y phishing" dentro de los reportes ejecutivos de TERO	Mostrar valor a la dirección